

DESAFIO



Pirâmide da Dor

100

Um atacante realizou uma ação relativamente simples na hierarquia de dificuldade no contexto da pirâmide da dor, isto é, ele modificou o hash MD5 de um artefato.

Você seria capaz de recuperar o hash original?

Máscara: FIAP{HASHMD5}



PONTUAÇÃO BÔNUS PARA OS PRIMEIROS A RESOLVEREM



+70 pts



+50 pts



+30 pts



dog.jpg

Bandeira

Enviar



Autopsy[®]

OPEN | EXTENSIBLE | FAST

Done loading modules.

Utilizado o XXD para analisar se o final do arquivo realmente bate um jpg.

```
00007840: f949 b1ff 00e3 1451 47d7 313f f3f6 5f7b .I....QG.1?..._{
00007850: 0ff5 6322 ff00 a00a 3ff8 2e1f fc88 7fc3 ..c"....?.....
00007860: 777c 73ff 00a1 e3ff 0029 363f fc62 bed4 w|s.....)6?.b..
00007870: fd83 7e33 f8c7 e347 837c 4f7d e32d 63fb ..~3...G.|0}.-c.
00007880: 62ea cefe 3820 93ec b0c1 b10c 6188 c448 b...8 .....a..H
00007890: a0f3 eb45 15ed e4f8 8ad5 715c b526 dab3 ...E.....q\.&..
000078a0: ddb6 7e5f e246 4995 e072 09d6 c261 69d3 ..~_.FI..r...ai.
000078b0: 9f34 758c 2317 bf74 933e a0a2 8a2b ee4f .4u.#...t.>...+.0
000078c0: e4a0 a28a 2800 a28a 2800 a28a 2800 a28a ....(...(.(...
000078d0: 2800 a28a 2800 a28a 2803 ffd9 0000 0000 (...(...(.....

(root@ DESKTOP-EM0E755)-[/mnt/f/Downloads]
# md5sum dog.jpg
0c457af3b9794fc0441fc8e009fb5fc3 dog.jpg
```

Neste caso, o arquivo precisa ser cortado logo após o marcador FF D9

O marcador FF D9 termina exatamente no offset hexadecimal 0x78DA

Utilizado o comando:

```
head -c 30940 dog.jpg > dog_original.jpg
md5sum dog_original.jpg
```

Onde obtemos o resultado:

FIAP{d3580a86012b483ec1a738bbdfaba4ef}

O atacante usou uma técnica muito simples: ele pegou a imagem original e apenas "colou" alguns bytes nulos (0000 0000...) no final do arquivo. Como a imagem continua abrindo normalmente (porque o visualizador para no FF D9), a olho nu nada mudou, mas o hash MD5 mudou completamente, quebrando a integridade.

Para reverter isso, precisávamos descobrir o tamanho exato da imagem original. Onde analisamos a última linha do xxd

Como as posições (offsets) começam a contar do zero, se o último byte está na posição 78db , o tamanho total do arquivo em hexadecimal é 78dc (um a mais).

O comando head -c 30940 dog.jpg > dog_original.jpg pegou os exatos 30.940 bytes originais da imagem (terminando cirurgicamente no FF D9) e descartou todo o "lixo" (0000 0000) que o atacante havia colocado no final.